

Universidad Autónoma de la Ciudad de México

Licenciatura en Ingeniería de Software

Análisis de Requisitos

Primer Avance de Proyecto

Expediente Médico Electrónico

Alumno: Edson Joel Carrera Avila

Alumno: Mauricio Bonifacio Hernández

Grupo: 302

Profesor: Prof. Mtro. Raul Rolando Jara Montes

Contents

1	Planteamiento	2
2	Alcance del proyecto	2
2.1	Funcionalidades	2
2.2	Funcionalidades excluidas	3
2.3	Límites técnicos	3
2.4	Límites de tiempo	4
3	Objetivos	4
3.1	Objetivo General	4
3.2	Objetivos específicos	4
4	Análisis de requisitos	5
4.1	Actores del sistema	5
4.2	Reglas de negocio	5
4.3	Requisitos funcionales	7
4.4	Requisitos no funcionales	11
5	Casos de uso	13
6	Tabla de trazabilidad	21
7	Diagramas UML	22
7.1	Diagrama de Casos de Uso	22
7.2	Diagrama de Secuencia: Nuevo Paciente y Agendamiento	22
7.3	Diagrama de Actividad: Autenticación con Seguridad	23
7.4	Diagrama de Componentes	23
7.5	Diagrama de Clases	24
7.6	Diagrama Entidad-Relación	24
7.7	Diagrama de Estados: Cita	25
7.8	Diagrama de Despliegue	25
8	Mockups	26
9	Conclusiones	29
10	Referencias	29
A	Estructura del prototipo	30
B	Tabla de endpoints REST	30

1. Planteamiento

En la actualidad, muchos consultorios médicos pequeños y medianos gestionan la información clínica de sus pacientes mediante expedientes en papel o herramientas no especializadas como hojas de cálculo. Esto provoca pérdida de información clínica relevante, duplicidad de registros entre el personal de recepción y el médico, demoras en la atención al paciente, dificultades para hacer seguimiento del historial médico y problemas para cumplir con los principios de confidencialidad y trazabilidad de los datos.

Se requiere un sistema web que permita al personal del consultorio —administradores, médicos y recepcionistas— registrar y consultar expedientes médicos electrónicos de forma centralizada, segura y eficiente. El sistema debe cubrir el caso de uso completo desde la apertura formal del expediente de un paciente nuevo —incluyendo la verificación previa de existencia, captura de datos demográficos y asignación de médico responsable— hasta la gestión de citas, el registro de consultas con prescripción de medicamentos y la administración integral de cuentas de usuarios.

El sistema de Expediente Médico Electrónico (EME) busca resolver la falta de plataformas accesibles para consultorios pequeños mediante una solución integral que mejore la calidad de la atención clínica, reduzca el tiempo administrativo, garantice la confidencialidad de los datos del paciente mediante control de acceso basado en roles (RBAC) y proporcione trazabilidad completa de todas las acciones mediante un registro de auditoría inmutable. El sistema implementa además medidas de ciberseguridad: protección contra fuerza bruta mediante *rate limiting*, cabeceras HTTP seguras vía `Helmet.js`, secreto criptográfico generado automáticamente en `.env`, sesión en `sessionStorage` y cierre automático por inactividad.

2. Alcance del proyecto

2.1. Funcionalidades

- Mecanismo de *Bootstrap de Seguridad* para la inicialización automática del primer administrador del sistema.
- Auto-configuración del entorno mediante el script `setup.js`, que genera un archivo `.env` con secreto criptográfico aleatorio único en cada instalación.
- Registro y autenticación de usuarios con tres roles diferenciados (Administrador, Médico, Recepcionista) y código único de recuperación de contraseña.
- Gestión integral de cuentas de usuario por parte del Administrador: creación, edición, activación y desactivación.
- Apertura formal de expedientes médicos electrónicos con verificación previa de existencia del paciente por CURP.
- Generación automática de número único de expediente con formato `EXP-YYYY-NNNNN`.
- Captura de datos demográficos del paciente (CURP, nombre, fecha de nacimiento, sexo, dirección, contacto).
- Registro de información clínica básica del paciente (tipo de sangre, alergias, observaciones).
- Asignación de médico responsable al expediente.
- Búsqueda inteligente de pacientes por nombre, apellido, CURP o teléfono.
- Eliminación lógica de pacientes (*Soft Delete*) con archivo automático del expediente y cancelación en cascada de citas pendientes; exclusiva del rol Médico.
- Restauración de pacientes eliminados por parte del Administrador.
- Programación de citas médicas desde el detalle del paciente, con paciente preseleccionado en el modal.
- Visualización de la agenda de citas filtrada por rol y por fecha (todas, hoy).

- Cancelación de citas con cambio de estado.
- Registro de consultas médicas con signos vitales (presión, peso, altura, temperatura, frecuencia cardiaca), motivo, síntomas, diagnóstico y plan de tratamiento.
- Prescripción electrónica de medicamentos vinculada a la consulta y al expediente.
- Registro y consulta de antecedentes médicos del paciente.
- Control de acceso basado en roles (RBAC) que diferencia datos administrativos de datos clínicos.
- Registro automático de auditoría inmutable de todas las acciones y eventos de seguridad.
- Consulta de auditoría propia por cada usuario y auditoría global para el Administrador.
- Dashboard interactivo con estadísticas adaptadas al rol del usuario.
- Cierre automático de sesión por inactividad (15 minutos) con aviso previo de 60 segundos.

2.2. Funcionalidades excluidas

- Gestión de seguros médicos (aseguradoras, pólizas, coberturas).
- Integración con sistemas de pago o facturación electrónica.
- Módulo de telemedicina o videollamadas integradas.
- Aplicación móvil nativa (iOS o Android).
- Módulo de farmacia o dispensación de medicamentos.
- Integración con laboratorios externos o dispositivos de monitoreo continuo.
- Verificación automática de interacciones medicamentosas.
- Firma digital certificada de recetas electrónicas.
- Mensajería interna entre médico y paciente.
- Integración con sistemas gubernamentales de salud.
- Notificaciones por correo electrónico o SMS.
- Generación automatizada de respaldos en la nube.
- Operación en múltiples sucursales simultáneamente.

2.3. Límites técnicos

- **Backend:** Node.js v18 o superior con Express.js.
- **Frontend:** HTML5, CSS3, JavaScript (Vanilla, sin frameworks). Arquitectura SPA.
- **Base de datos:** SQLite mediante la biblioteca sql.js (sin instalación externa).
- **Autenticación:** JSON Web Tokens (JWT, 24h) en `sessionStorage`, con auto-cierre por inactividad a los 15 minutos.
- **Cifrado:** bcryptjs (10 rondas) para hash de contraseñas y códigos de recuperación.
- **Seguridad HTTP:** Helmet.js (cabeceras de seguridad) y express-rate-limit (5 intentos/15 min) nativos.
- **Configuración:** dotenv para gestión de secretos; auto-generación del `.env` mediante `setup.js`.
- **Sistema operativo de desarrollo:** Linux (Ubuntu), compatible también con Windows y macOS mediante scripts autoejecutables (`iniciar.sh`, `iniciar.bat`).
- **Navegadores soportados:** Chrome 120+, Firefox 120+, Edge 120+ y Safari 17+.
- **Control de versiones:** Git.
- **Idioma:** Español (México).

2.4. Límites de tiempo

- **Avance 1:** Planteamiento, análisis de requisitos, casos de uso, diagramas UML y modelo de datos definidos.
- **Avance 2:** Módulo de autenticación, apertura formal de expediente y gestión de citas implementados con auditoría.
- **Avance 3:** Incorporación del rol Administrador, eliminación lógica de pacientes, hub de pacientes, hardening de seguridad (Helmet, rate limiting, sessionStorage, timeout de inactividad, .env auto-generado).
- **Entrega final:** Sistema completo con consultas médicas, prescripciones, control de acceso por roles, auditoría global y documentación conforme al estándar IEEE 830.

3. Objetivos

3.1. Objetivo General

Desarrollar un sistema web de gestión de expedientes médicos electrónicos con Node.js y Express que permita al personal de un consultorio médico pequeño —Administrador, Médicos y Recepcionistas— registrar, consultar y administrar la información clínica y administrativa de los pacientes de forma segura, eficiente y trazable, incorporando medidas de ciberseguridad, control de acceso basado en roles (RBAC) y auditoría completa, conforme al estándar IEEE 830-1998.

3.2. Objetivos específicos

- OE1:** Implementar el módulo de apertura formal de expediente médico con verificación previa de existencia, captura de datos demográficos y generación automática de número único.
- OE2:** Desarrollar el módulo de autenticación con tres roles diferenciados, incluyendo registro inicial automatizado (*bootstrap*), inicio de sesión, limitadores de fuerza bruta, recuperación por código único y cierre automático por inactividad.
- OE3:** Implementar la gestión de citas médicas con agendamiento centrado en el paciente, cancelación y visualización de la agenda según el rol del usuario autenticado.
- OE4:** Desarrollar el módulo de consultas médicas exclusivo para médicos, incluyendo registro de signos vitales, diagnóstico, plan de tratamiento y prescripción de medicamentos.
- OE5:** Construir el sistema de control de acceso basado en roles (RBAC) que garantice que las recepcionistas no accedan a datos clínicos sensibles y que el administrador no acceda a expedientes.
- OE6:** Implementar el módulo de auditoría inmutable que registre automáticamente todas las acciones modificadoras del sistema (creación, actualización, eliminación lógica) con información del usuario, IP, fecha y hora.
- OE7:** Incorporar medidas de ciberseguridad: cabeceras HTTP seguras, *rate limiting*, gestión de secretos por variables de entorno y almacenamiento de sesión no persistente.
- OE8:** Generar la documentación formal del proyecto conforme al estándar IEEE 830-1998, incluyendo casos de uso detallados, diagramas UML y tabla de trazabilidad.

4. Análisis de requisitos

4.1. Actores del sistema

Los actores que interactúan con el sistema EME se describen a continuación:

Actor	Descripción	Permisos principales
Administrador	Encargado de TI o gestor de la clínica responsable de la configuración del sistema y la gestión de cuentas. No accede a información clínica.	Crear, editar y activar/desactivar cuentas de usuarios (médicos, recepcionistas y otros administradores). Restaurar pacientes eliminados. Consultar auditoría global y estadísticas del sistema. Acceso especial mediante <i>bootstrap</i> en la primera instalación.
Médico	Profesional de la salud que registra consultas, prescribe medicamentos y gestiona el expediente clínico del paciente.	Abrir y consultar expedientes. Registrar consultas y diagnósticos. Generar prescripciones de medicamentos. Registrar antecedentes médicos. Gestionar citas. Eliminar pacientes lógicamente (con motivo obligatorio). Consultar su auditoría.
Recepcionista	Personal del consultorio que gestiona citas, registra pacientes nuevos y abre expedientes con sus datos demográficos.	Abrir y consultar expedientes (sin datos clínicos). Registrar y editar datos demográficos del paciente. Programar citas para cualquier médico. Consultar su auditoría.
Sistema	Componente interno que ejecuta lógica de negocio, validaciones, generación de entorno seguro y persiste datos.	Generación automática de identificadores únicos (EXP-YYYY-NNNNN). Validación de reglas de negocio. Cifrado de credenciales con <code>bcrypt</code> . Registro automático de auditoría. Generación de entorno seguro (<code>.env</code> mediante <code>setup.js</code>). Limitación de peticiones (Rate Limit). Generación de tokens JWT.

4.2. Reglas de negocio

- RN1:** Cada paciente debe tener un identificador único (CURP) que no puede repetirse en la base de datos.
- RN2:** Cada expediente médico debe tener un número único con formato **EXP-YYYY-NNNNN**, donde **YYYY** es el año actual y **NNNNN** es un número secuencial dentro del año.
- RN3:** No se permite la creación de un nuevo expediente si ya existe uno asociado a la misma CURP.
- RN4:** Un paciente puede existir en el sistema sin expediente, pero un expediente siempre debe estar asociado a un paciente.

- RN5:** El correo electrónico de cada usuario del sistema debe ser único en la base de datos.
- RN6:** El número de licencia profesional debe ser único y es obligatorio para usuarios con rol de médico.
- RN7:** Las contraseñas deben cifrarse mediante bcrypt (10 rondas) antes de persistirse.
- RN8:** El código de recuperación de contraseña debe cifrarse con bcrypt antes de persistirse y debe regenerarse cada vez que el usuario cambia su contraseña.
- RN9:** El código de recuperación se muestra al usuario una única vez al momento del registro y al cambiar contraseña; el sistema no permite recuperarlo posteriormente.
- RN10:** Solo usuarios activos pueden iniciar sesión en el sistema.
- RN11:** La sesión JWT expira tras 24 horas desde el inicio.
- RN12:** El token temporal para restablecer contraseña expira tras 15 minutos.
- RN13:** Las contraseñas deben tener una longitud mínima de 8 caracteres e incluir al menos una mayúscula, una minúscula y un número.
- RN14:** El sistema registra la fecha y hora de creación de cada expediente de forma automática e inalterable.
- RN15:** Solo usuarios con rol de médico pueden crear consultas médicas, registrar diagnósticos y prescribir medicamentos.
- RN16:** Las recepcionistas no tienen acceso a datos clínicos del paciente (consultas, diagnósticos, antecedentes médicos) aunque pueden ver sus datos demográficos y de contacto.
- RN17:** Cuando una consulta médica se asocia a una cita, el estado de la cita cambia automáticamente a **completada**.
- RN18:** Una cita puede tener estados: **pendiente**, **completada** o **cancelada**.
- RN19:** Las prescripciones de medicamentos se registran automáticamente como antecedentes del paciente con tipo **prescripción**.
- RN20:** Cada acción modificadora (crear, actualizar, eliminar) realizada en el sistema queda registrada en el log de auditoría con usuario, rol, acción, entidad afectada, IP, user-agent y fecha/hora.
- RN21:** Los registros de auditoría no pueden modificarse ni eliminarse una vez creados.
- RN22:** Los intentos fallidos de inicio de sesión se registran en la auditoría con la marca **LOGIN_FAILED**.
- RN23:** Los intentos de acceso a recursos no autorizados (por rol insuficiente) se registran como **ACCESS_DENIED** en la auditoría.
- RN24:** Cada usuario solo puede consultar su propia auditoría; el Administrador tiene acceso adicional a la auditoría global del sistema.
- RN25:** El sistema opera en idioma español; todos los mensajes, errores y notificaciones se muestran en este idioma.
- RN26:** El primer usuario registrado en el sistema debe asumir obligatoriamente el rol de Administrador (proceso de *Bootstrap*).

- RN27:** La eliminación de pacientes es de tipo lógica (*Soft Delete*): se marcan como inactivos y se archiva su expediente, preservando el historial clínico por normatividad.
- RN28:** El sistema cierra automáticamente la sesión del usuario tras 15 minutos de inactividad, mostrando una advertencia 60 segundos antes del cierre efectivo.
- RN29:** El sistema bloquea temporalmente los intentos de inicio de sesión tras 5 intentos fallidos durante 15 minutos para prevenir ataques de fuerza bruta.
- RN30:** Solo el Administrador puede crear, editar y desactivar cuentas de usuario; los demás roles no acceden a este módulo.
- RN31:** No puede desactivarse al último Administrador activo del sistema ni un Administrador puede desactivarse a sí mismo.
- RN32:** Solo el Administrador puede restaurar pacientes eliminados; al restaurarse, su expediente vuelve a estado **activo**.
- RN33:** La sesión se almacena en **sessionStorage** y se destruye automáticamente al cerrar el navegador (sesión no persistente).
- RN34:** Toda edición de datos de un paciente requiere un motivo obligatorio (mínimo 5 caracteres) que queda registrado en auditoría.
- RN35:** Las citas se agendan desde el detalle del paciente; el paciente queda preseleccionado en el modal de agendamiento.
- RN36:** Al eliminar un paciente (*Soft Delete*), todas sus citas en estado **pendiente** se cancelan automáticamente en cascada.
- RN37:** El secreto JWT se configura mediante variable de entorno (**.env**) y nunca aparece en el código fuente; se genera aleatoriamente en cada instalación.
- RN38:** Los archivos sensibles (**eme.db**, **.env**) devuelven HTTP 403 si se intenta acceder a ellos por URL.
- RN39:** Los mensajes de error de inicio de sesión son genéricos (no revelan si el email existe o si la contraseña es incorrecta).

4.3. Requisitos funcionales

ID	Descripción	Actor principal	Prior.	Criterio de aceptación
RF01	Registrar nuevos usuarios del sistema con datos personales, credenciales y rol asignado.	Administrador / Bootstrap	Alta	El sistema valida unicidad de email y licencia, exige contraseña robusta, genera código único de recuperación y audita la acción. En <i>bootstrap</i> no requiere autenticación; tras él, solo el admin puede registrar.

ID	Descripción	Actor principal	Prior.	Criterio de aceptación
RF02	Autenticar usuarios mediante email y contraseña, generando token JWT.	Todos	Alta	El sistema valida credenciales, comprueba que el usuario esté activo, aplica <i>rate limiting</i> (5 intentos / 15 min), registra el inicio de sesión en auditoría y redirige al dashboard según rol.
RF03	Permitir al usuario cerrar sesión de forma segura, manualmente o automáticamente por inactividad.	Todos	Alta	El sistema elimina el token del <code>sessionStorage</code> ; cierra la sesión tras 15 min sin actividad, con aviso 60 seg antes; las peticiones posteriores con el token eliminado son rechazadas.
RF04	Permitir recuperar la contraseña mediante código único generado al registrarse.	Todos	Alta	El sistema valida email + código contra el hash almacenado, genera token de reset de 15 minutos y permite establecer nueva contraseña; se genera un nuevo código tras el cambio.
RF05	Verificar la existencia previa de un paciente por CURP antes de abrir un nuevo expediente.	Médico / Recepcionista	Alta	El sistema busca en la BD por CURP y devuelve los datos del paciente y su expediente si existen; sino, indica que no existe.
RF06	Abrir formalmente un expediente médico con captura de datos demográficos y motivo de apertura.	Médico / Recepcionista	Alta	El sistema valida campos obligatorios, genera número único <code>EXP-YYYY-NNNNN</code> , crea el paciente, registra el expediente y audita la acción.
RF07	Listar los pacientes activos con su número de expediente.	Médico / Recepcionista	Alta	El sistema retorna en menos de 1 segundo la lista paginada; permite filtrado por término. Solo pacientes con <code>activo=1</code> .

ID	Descripción	Actor principal	Prior.	Criterio de aceptación
RF08	Búsqueda inteligente de pacientes por nombre, apellido, CURP o teléfono.	Médico / Recepcionista	Alta	El sistema busca coincidencias parciales (mínimo 3 caracteres) en cualquiera de los campos y devuelve resultados ordenados por relevancia.
RF09	Consultar el detalle completo de un paciente, filtrado según el rol.	Médico / Recepcionista	Alta	El sistema retorna datos demográficos y expediente para ambos roles; para médicos retorna además antecedentes y consultas.
RF10	Editar datos del paciente con motivo obligatorio para auditoría.	Médico / Recepcionista	Alta	El sistema valida que el motivo tenga al menos 5 caracteres y registra los datos antes/después en JSON en la auditoría.
RF11	Eliminar lógicamente (<i>Soft Delete</i>) un paciente con cascada sobre expediente y citas pendientes.	Médico	Alta	El sistema marca activo=0 , archiva el expediente, cancela citas pendientes automáticamente y registra en auditoría el motivo de eliminación.
RF12	Listar y restaurar pacientes eliminados.	Administrador	Alta	El sistema lista pacientes con activo=0 ; al restaurarlos, reactiva el paciente, su expediente y se registra la acción en auditoría.
RF13	Programar citas médicas asignadas a un médico específico desde el detalle del paciente.	Médico / Recepcionista	Alta	El sistema valida campos obligatorios, no permite fechas anteriores al día actual, preselecciona al paciente, registra al usuario que la agendó y persiste con estado pendiente .

ID	Descripción	Actor principal	Prior.	Criterio de aceptación
RF14	Visualizar la agenda de citas (todas y las del día).	Médico / Recepcionista	Alta	El sistema retorna las citas con información del paciente y del médico; ordena cronológicamente; muestra el estado de cada cita.
RF15	Cancelar una cita pendiente, cambiando su estado a cancelada .	Médico / Recepcionista	Alta	El sistema cambia el estado, registra la acción en auditoría y la cita ya no aparece como atendible.
RF16	Registrar una consulta médica con signos vitales, motivo, síntomas, diagnóstico, plan de tratamiento y prescripciones.	Médico	Alta	El sistema valida campos obligatorios, persiste la consulta, las prescripciones se registran como antecedentes; si existe una cita asociada se marca como completada .
RF17	Registrar antecedentes médicos del paciente.	Médico	Alta	El sistema permite registrar condiciones crónicas, alergias y prescripciones, asociados al paciente y opcionalmente a una consulta.
RF18	Bloquear el acceso a endpoints de consultas y antecedentes médicos para usuarios sin rol médico.	Sistema	Alta	El middleware requireRole('medico') retorna HTTP 403 ante peticiones no autorizadas y registra ACCESS_DENIED en auditoría.
RF19	Gestionar (CRUD) cuentas de usuario del sistema.	Administrador	Alta	El sistema permite al admin crear, editar, activar y desactivar usuarios, con las restricciones de no auto-desactivación y no desactivación del último admin.

ID	Descripción	Actor principal	Prior.	Criterio de aceptación
RF20	Registrar automáticamente en la tabla de auditoría toda acción modificadora del sistema.	Sistema	Alta	El sistema registra cada operación exitosa o fallida; los datos antes y después se almacenan como JSON; cada registro incluye IP, user-agent y timestamp.
RF21	Permitir a cada usuario consultar su propia actividad de auditoría (últimas 100 acciones).	Todos	Media	El sistema retorna las acciones del usuario actual ordenadas por fecha descendente.
RF22	Permitir al Administrador consultar la auditoría global con filtros.	Administrador	Alta	El sistema retorna los últimos 200 registros del sistema con filtros por tipo de acción y email del usuario; ordenados cronológicamente.
RF23	Mostrar un dashboard interactivo con estadísticas adaptadas al rol.	Todos	Media	El admin ve estadísticas del sistema; el médico ve sus citas y consultas; la recepcionista ve la agenda global del consultorio.
RF24	Listar los médicos disponibles para asignar como responsables.	Médico / Recepcionista / Admin	Media	El sistema retorna solo los usuarios activos con rol <code>medico</code> , ordenados por apellido.
RF25	Autoconfiguración del entorno seguro en la primera ejecución.	Sistema	Alta	El script <code>setup.js</code> verifica la existencia del <code>.env</code> ; si no existe, genera uno con <code>JWT_SECRET</code> aleatorio de 64 caracteres hexadecimales y los demás parámetros de seguridad.

4.4. Requisitos no funcionales

ID	Descripción	Categoría	Métrica / criterio
RNF01	Tiempos de respuesta rápidos para las operaciones más comunes.	Rendimiento	La búsqueda de pacientes debe responder en ≤ 500 ms con hasta 1.000 registros; cualquier pantalla debe cargar en ≤ 3 segundos.

ID	Descripción	Categoría	Métrica / criterio
RNF02	Contraseñas y códigos de recuperación cifrados con hash seguro. Tokens JWT con expiración.	Seguridad	Hash bcrypt con 10 rondas; JWT con expiración de 24 horas para sesión y 15 minutos para reset; consultas SQL con prepared statements.
RNF03	Control de acceso basado en roles (RBAC) que separe los permisos administrativos, clínicos y operativos.	Seguridad	El middleware <code>requireRole()</code> retorna HTTP 403 cuando un usuario sin rol autorizado intenta acceder; los intentos se registran en auditoría como <code>ACCESS_DENIED</code> .
RNF04	Protección ante ataques de fuerza bruta en la autenticación.	Seguridad	Rate limiting: máximo 5 intentos por IP cada 15 minutos en el endpoint de login; los excedentes reciben HTTP 429.
RNF05	Cabeceras de seguridad HTTP en todas las respuestas.	Seguridad	Helmet.js activa automáticamente X-Frame-Options: SAMEORIGIN, X-Content-Type-Options: nosniff, Referrer-Policy: no-referrer y otras cabeceras de hardening.
RNF06	Gestión segura de secretos y configuración.	Seguridad	JWT_SECRET cargado desde <code>.env</code> no versionado en Git; auto-generación aleatoria del secreto en cada instalación mediante <code>setup.js</code> .
RNF07	Sesión no persistente entre sesiones de navegador.	Seguridad	Token JWT en <code>sessionStorage</code> ; se destruye automáticamente al cerrar la pestaña o el navegador.
RNF08	Cierre de sesión automático por inactividad.	Seguridad	Tras 15 min de inactividad, aviso modal de 60 segundos; si no hay respuesta, se cierra la sesión automáticamente.
RNF09	Bloqueo de acceso por URL a archivos sensibles.	Seguridad	Los archivos <code>eme.db</code> y <code>.env</code> devuelven HTTP 403 si se intenta acceder a ellos vía URL pública.
RNF10	Interfaz clara, intuitiva y adaptable a diferentes tamaños de pantalla.	Usabilidad	Compatible con Chrome 120+, Firefox 120+, Edge 120+ y Safari 17+; resolución mínima 1024×768; diseño responsive minimalista.

ID	Descripción	Categoría	Métrica / criterio
RNF11	Operación sin dependencias externas para la base de datos.	Portabilidad	El sistema usa SQLite embebido mediante sql.js; el archivo <code>eme.db</code> se crea automáticamente al iniciar el servidor.
RNF12	Autoconfiguración del entorno de ejecución multiplataforma.	Portabilidad	El sistema auto-genera el archivo <code>.env</code> en la primera ejecución y se ejecuta en Linux, Windows y macOS con Node.js v18+ mediante scripts autoejecutables.
RNF13	Código estructurado y modular para facilitar mantenibilidad.	Mantenibilidad	Backend organizado en módulos funcionales dentro de <code>server.js</code> ; frontend desacoplado mediante llamadas a la API REST.
RNF14	Registro de auditoría inmutable de todas las acciones del sistema.	Trazabilidad	La tabla <code>auditoria</code> registra usuario, rol, acción, entidad, ID, IP, user-agent, datos antes/después en JSON y timestamp; los registros no se modifican ni eliminan.
RNF15	Confidencialidad de los datos clínicos del paciente.	Privacidad	Los datos clínicos (consultas, diagnósticos, antecedentes) solo son visibles para usuarios con rol <code>medico</code> ; las recepcionistas y administradores no pueden acceder a ellos por ningún endpoint.
RNF16	Documentación formal conforme al estándar IEEE 830-1998.	Normatividad	El proyecto incluye Especificación de Requisitos Software (ERS) con todas las secciones del estándar; los diagramas UML están documentados en PlantUML.
RNF17	Idioma único en interfaz, mensajes y errores.	Localización	Toda la interfaz, mensajes de error y notificaciones se presentan en español (México).
RNF18	Integridad de los datos clínicos preservada ante eliminaciones.	Integridad	La eliminación de pacientes es lógica; los datos clínicos nunca se borran físicamente, garantizando trazabilidad histórica completa.

5. Casos de uso

A continuación se documentan los casos de uso principales del sistema EME, alineados con los tres roles implementados (Administrador, Médico y Recepcionista).

CU01: Bootstrap del Administrador inicial

ID	CU01
Nombre	Bootstrap del Administrador inicial
Actor principal	Usuario inicial (futuro Administrador)
Descripción	Permite registrar el primer usuario del sistema con rol Administrador sin requerir autenticación previa, únicamente cuando no existe ningún administrador.
Precondición	El sistema no tiene usuarios con rol admin activos.
Postcondición	Se crea el primer Administrador y se cierra la posibilidad de registro abierto.
Flujo principal	1. El usuario accede a http://localhost:3000. 2. El sistema detecta que no existe administrador y muestra la pantalla de bienvenida. 3. El usuario hace clic en “Crear administrador”. 4. El sistema solicita nombre, apellido, email, teléfono y contraseña. 5. El usuario completa los datos. 6. El sistema valida los datos y la robustez de la contraseña. 7. El sistema crea la cuenta con rol admin, hashea la contraseña con bcrypt y genera un código de recuperación único. 8. El sistema registra la acción BOOTSTRAP_ADMIN en auditoría. 9. El sistema muestra el código de recuperación al usuario.
Flujo alternativo	6a. Si los datos no son válidos o la contraseña no cumple los requisitos, el sistema muestra el error correspondiente y permanece en el formulario.

CU02: Iniciar sesión

ID	CU02
Nombre	Iniciar sesión
Actor principal	Administrador / Médico / Recepcionista
Descripción	El usuario se autentica en el sistema mediante su email y contraseña.
Precondición	El usuario tiene una cuenta activa en el sistema.
Postcondición	Se establece una sesión autenticada con token JWT en sessionStorage y se inicia el monitor de inactividad.

Flujo principal	1. El usuario accede a la pantalla de login. 2. El usuario ingresa email y contraseña. 3. El sistema verifica el rate-limit (máx. 5 intentos / 15 min por IP). 4. El sistema valida las credenciales contra la base de datos. 5. El sistema verifica que la cuenta esté activa. 6. El sistema genera token JWT con expiración de 24 horas. 7. El sistema registra la acción LOGIN en auditoría. 8. El frontend almacena el token en sessionStorage. 9. El frontend inicia el monitor de inactividad (15 minutos). 10. El sistema redirige al dashboard según el rol.
Flujo alternativo 4a. Si las credenciales son incorrectas, registra LOGIN_FAILED y muestra mensaje genérico. 5a. Si la cuenta está desactivada, muestra el mismo mensaje genérico.	3a. Si se supera el rate-limit, el sistema retorna HTTP 429 y bloquea por 15 min.

CU03: Cerrar sesión (manual o por inactividad)

ID	CU03
Nombre	Cerrar sesión
Actor principal	Todos los roles autenticados
Descripción	El usuario cierra sesión manualmente o el sistema lo hace automáticamente tras 15 min de inactividad.
Precondición	El usuario tiene una sesión activa.
Postcondición	El token JWT se elimina del sessionStorage y el usuario es redirigido al login.
Flujo principal (manual)	1. El usuario hace clic en “Cerrar sesión”. 2. El sistema elimina el token del sessionStorage. 3. El sistema registra LOGOUT en auditoría. 4. El sistema redirige a la pantalla de login.

Flujo alternativo (por inactividad)	1. El monitor detecta 14 minutos de inactividad. 2. El sistema muestra modal con cuenta regresiva de 60 segundos. 3. Si el usuario hace clic en “Continuar”, el contador se reinicia. 4. Si transcurren los 60 segundos sin acción, el sistema cierra la sesión automáticamente.
--	---

CU04: Gestionar usuarios del sistema

ID	CU04
Nombre	Gestionar usuarios del sistema
Actor principal	Administrador
Descripción	El Administrador crea, edita, activa o desactiva cuentas de usuario (Médicos, Recepcionistas u otros Administradores).
Precondición	El Administrador está autenticado.
Postcondición	La base de usuarios queda actualizada y la acción registrada en auditoría.
Flujo principal	1. El Administrador accede al módulo “Gestión de usuarios”. 2. El sistema lista todos los usuarios (activos e inactivos). 3. El Administrador selecciona una acción: “Crear”, “Editar” o “Activar/Desactivar”. 4. El sistema valida los datos y las reglas de negocio (unicidad de email/licencia, no auto-desactivación, no desactivar al último admin). 5. El sistema persiste el cambio y registra la acción en auditoría.
Flujo alternativo	4a. Si se intenta desactivar al último admin, el sistema lo bloquea con un mensaje específico.
4b. Si el admin intenta desactivarse a sí mismo, el sistema lo bloquea.	

CU05: Apertura de expediente médico

ID	CU05
Nombre	Apertura de expediente médico (paciente nuevo)
Actor principal	Médico / Recepcionista
Descripción	Permite registrar a un paciente nuevo y abrir su expediente clínico en un solo flujo.
Precondición	El usuario está autenticado con rol médico o recepcionista.
Postcondición	Se crean los registros paciente y expediente con identificadores únicos.

Flujo principal	1. El usuario accede al módulo “Pacientes”. 2. El usuario hace clic en “+ Nuevo paciente” y aparece el modal. 3. El usuario llena CURP, nombre, apellido, fecha de nacimiento, sexo y motivo de apertura. 4. El sistema verifica que la CURP no exista previamente. 5. El sistema crea el paciente y el expediente con número EXP-YYYY-MNNNN. 6. El sistema registra las acciones CREATE pacientes y CREATE expedientes en auditoría. 7. El sistema muestra confirmación con el número de expediente generado.
Flujo alternativo	4a. Si la CURP ya existe, el sistema muestra el paciente existente y permite agendar cita en lugar de crear duplicado.

CU06: Búsqueda inteligente de pacientes

ID	CU06
Nombre	Búsqueda inteligente de pacientes
Actor principal	Médico / Recepcionista
Descripción	Permite localizar pacientes por nombre, apellido, CURP o teléfono.
Precondición	El usuario está autenticado.
Postcondición	Se muestran los resultados coincidentes.
Flujo principal	1. El usuario ingresa el término en la barra de búsqueda (mínimo 3 caracteres). 2. El sistema busca coincidencias parciales en nombre, apellido, CURP y teléfono. 3. El sistema retorna los resultados ordenados por relevancia.

CU07: Editar datos del paciente con motivo

ID	CU07
Nombre	Editar datos del paciente
Actor principal	Médico / Recepcionista
Descripción	Permite actualizar la información demográfica de un paciente, registrando el motivo del cambio.
Precondición	El paciente existe y está activo.
Postcondición	Los datos quedan actualizados con auditoría detallada.

Flujo principal	1. El usuario abre el detalle del paciente. 2. El usuario hace clic en “Editar” y modifica los campos necesarios. 3. El sistema exige un motivo de al menos 5 caracteres. 4. El sistema persiste los cambios y registra en auditoría datos antes/después.
------------------------	--

CU08: Eliminación lógica de paciente

ID	CU08
Nombre	Eliminación lógica de paciente (Soft Delete)
Actor principal	Médico
Descripción	El Médico elimina lógicamente a un paciente con motivo obligatorio. Sus citas pendientes se cancelan en cascada.
Precondición	El paciente existe y está activo. El usuario tiene rol Médico.
Postcondición	El paciente queda con activo=0 ; su expediente pasa a archivado ; sus citas pendientes a cancelada .
Flujo principal	1. El Médico accede al detalle del paciente y hace clic en “Eliminar”. 2. El sistema solicita el motivo de eliminación. 3. El sistema marca activo=0, archiva el expediente y cancela las citas pendientes. 4. El sistema registra DELETE pacientes con datos antes/después en auditoría.
Flujo alternativo	1a. Si el usuario es Recepcionista, el botón no aparece. Si intenta vía API, recibe HTTP 403 y se registra ACCESS_DENIED .

CU09: Restaurar paciente eliminado

ID	CU09
Nombre	Restaurar paciente eliminado
Actor principal	Administrador
Descripción	El Administrador restaura un paciente previamente eliminado, reactivando también su expediente.
Precondición	El paciente tiene activo=0 . El usuario tiene rol Administrador.
Postcondición	El paciente recupera activo=1 ; su expediente vuelve a activo .

Flujo principal	1. El Admin abre el módulo “Pacientes eliminados”. 2. El sistema lista los pacientes con activo=0. 3. El Admin hace clic en “Restaurar” del paciente seleccionado. 4. El sistema actualiza activo=1, reactiva el expediente y registra RESTORE en auditoría.
------------------------	--

CU10: Agendar cita desde el paciente

ID	CU10
Nombre	Agendar cita desde el detalle del paciente
Actor principal	Médico / Recepcionista
Descripción	Permite agendar una cita con el paciente preseleccionado en el modal.
Precondición	El paciente existe y está activo.
Postcondición	Se crea una cita en estado pendiente .
Flujo principal	1. El usuario abre el detalle del paciente y hace clic en “Agendar cita”. 2. El sistema abre el modal con el paciente preseleccionado. 3. El usuario selecciona fecha, hora, médico y motivo. 4. El sistema valida que la fecha no sea anterior al día actual. 5. El sistema persiste la cita y registra CREATE citas en auditoría.

CU11: Registrar consulta médica

ID	CU11
Nombre	Registrar consulta médica
Actor principal	Médico
Descripción	El Médico registra signos vitales, motivo, síntomas, diagnóstico, plan de tratamiento y prescripciones.
Precondición	El paciente existe y el usuario tiene rol Médico.
Postcondición	Se crea la consulta y las prescripciones quedan registradas como antecedentes; si hay cita asociada, su estado pasa a completada .

Flujo principal	1. El Médico accede al detalle del paciente y hace clic en “Nueva consulta”. 2. El Médico llena los signos vitales y los campos clínicos. 3. El Médico añade los medicamentos prescritos. 4. El sistema persiste la consulta y los antecedentes de tipo prescripcion. 5. El sistema actualiza el estado de la cita asociada si existe. 6. El sistema registra CREATE consultas y CREATE antecedentes en auditoría.
------------------------	--

CU12: Consultar mi actividad de auditoría

ID	CU12
Nombre	Consultar mi actividad
Actor principal	Todos los roles
Descripción	Permite a cada usuario ver sus últimas 100 acciones registradas en auditoría.
Precondición	El usuario está autenticado.
Postcondición	Se muestra la lista de acciones del propio usuario.
Flujo principal	1. El usuario accede al módulo “Mi actividad”. 2. El sistema consulta la auditoría filtrada por el ID del usuario en sesión. 3. El sistema retorna las últimas 100 acciones ordenadas por fecha descendente.

CU13: Consultar auditoría global

ID	CU13
Nombre	Consultar auditoría global
Actor principal	Administrador
Descripción	Permite al Administrador consultar la actividad de todos los usuarios del sistema con filtros.
Precondición	El usuario tiene rol Administrador.
Postcondición	Se muestra el listado filtrado de auditoría.
Flujo principal	1. El Admin accede al módulo “Auditoría global”. 2. El sistema retorna los últimos 200 registros del sistema. 3. El Admin aplica filtros por tipo de acción o email del usuario.

CU14: Recuperar contraseña por código único

ID	CU14
Nombre	Recuperar contraseña

Actor principal	Todos los roles
Descripción	El usuario restablece su contraseña usando el código único que recibió al registrarse.
Precondición	El usuario conoce su código de recuperación (formato EME-XXXX-XXXX-XXXX-XXXX).
Postcondición	La contraseña se actualiza y se genera un nuevo código.
Flujo principal	1. El usuario hace clic en “¿Olvidaste tu contraseña?”. 2. El usuario ingresa su email y código de recuperación. 3. El sistema valida el código contra el hash bcrypt almacenado. 4. El sistema genera token temporal válido por 15 minutos. 5. El usuario establece la nueva contraseña (validando robustez). 6. El sistema actualiza la contraseña y genera un nuevo código de recuperación. 7. El sistema muestra el nuevo código una única vez.

6. Tabla de trazabilidad

La siguiente tabla relaciona los casos de uso con las reglas de negocio (RN) y los requisitos funcionales (RF) que cubren, garantizando la trazabilidad completa entre los elementos del análisis.

Caso de uso	Reglas de negocio	Requisitos funcionales
CU01: Bootstrap del Admin	RN5, RN6, RN7, RN8, RN9, RN13, RN20, RN26	RF01, RF20, RF25
CU02: Iniciar sesión	RN10, RN11, RN20, RN22, RN29, RN39	RF02, RF20
CU03: Cerrar sesión	RN20, RN28, RN33	RF03, RF20
CU04: Gestionar usuarios	RN5, RN6, RN7, RN13, RN20, RN30, RN31	RF01, RF19, RF20
CU05: Apertura de expediente	RN1, RN2, RN3, RN4, RN14, RN20	RF05, RF06, RF20
CU06: Búsqueda de pacientes	—	RF07, RF08
CU07: Editar paciente	RN20, RN34	RF10, RF20
CU08: Eliminación lógica	RN20, RN27, RN36	RF11, RF18, RF20
CU09: Restaurar paciente	RN20, RN32	RF12, RF20
CU10: Agendar cita	RN18, RN20, RN35	RF13, RF20
CU11: Registrar consulta	RN15, RN16, RN17, RN19, RN20	RF16, RF17, RF18, RF20
CU12: Mi actividad	RN24	RF21
CU13: Auditoría global	RN20, RN21, RN24	RF22
CU14: Recuperar contraseña	RN8, RN9, RN12, RN13, RN20	RF04, RF20
Casos de sistema	RN20, RN21, RN37, RN38	RF20, RF23, RF24, RF25

7. Diagramas UML

El proyecto cuenta con 8 diagramas UML formales que documentan la arquitectura, comportamiento y modelo de datos del sistema. Cada diagrama está disponible en formato PlantUML editable en el archivo `EME_Diagramas_PlantUML.md`.

7.1. Diagrama de Casos de Uso

Muestra los tres actores del sistema (Administrador, Médico y Recepcionista) con sus 22 casos de uso agrupados en seis paquetes: Autenticación, Gestión de Usuarios, Gestión de Pacientes, Citas, Clínico (solo Médico) y Auditoría.

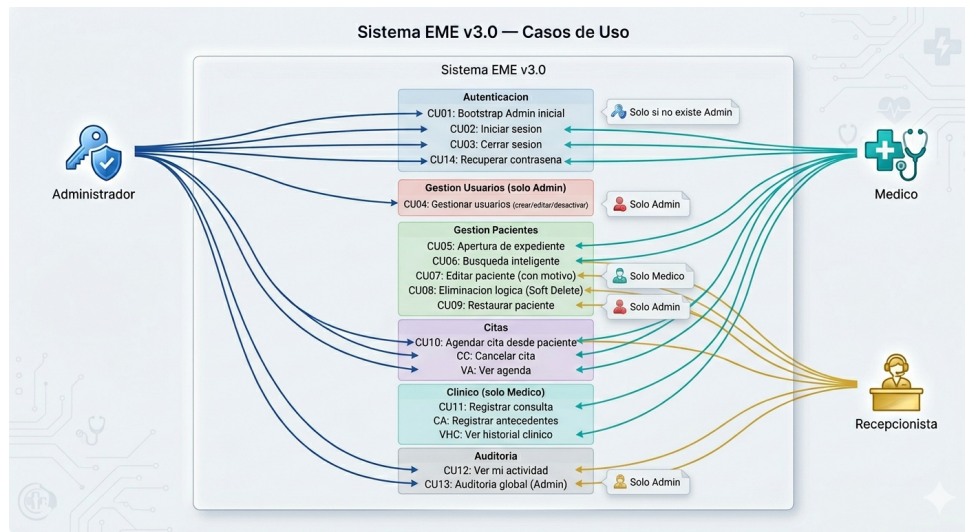


Figure 1: Diagrama de Casos de Uso

7.2. Diagrama de Secuencia: Nuevo Paciente y Agendamiento

Detalla el flujo completo desde la búsqueda previa del paciente en el hub, su creación mediante el modal unificado y el agendamiento inmediato de su primera cita con el paciente preseleccionado.

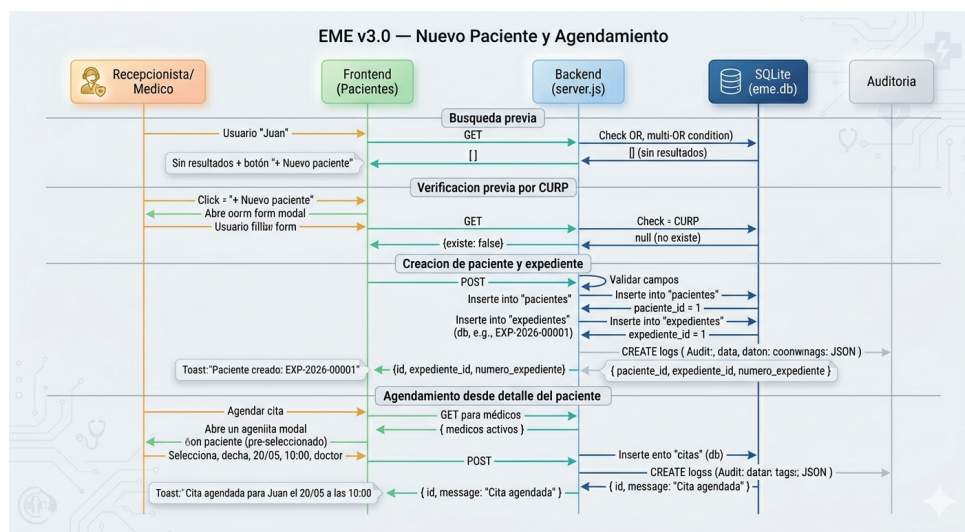


Figure 2: Diagrama de Secuencia: Nuevo Paciente y Agendamiento de Cita

7.3. Diagrama de Actividad: Autenticación con Seguridad

Representa el flujo completo de autenticación incluyendo las medidas de seguridad implementadas: verificación de rate limiting (5 intentos / 15 minutos), validación de credenciales con mensajes genéricos, almacenamiento en `sessionStorage`, inicio del monitor de inactividad de 15 minutos, aviso previo de 60 segundos y logout automático.

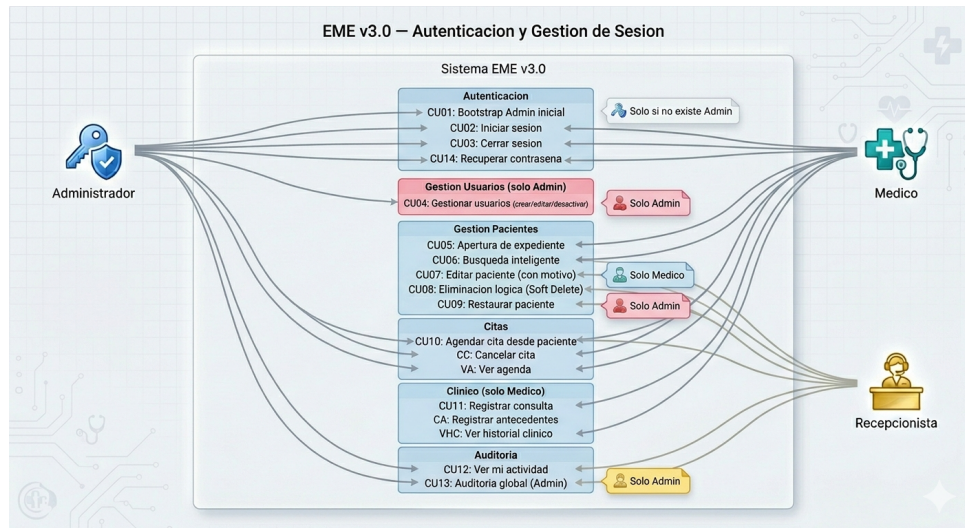


Figure 3: Diagrama de Actividad: Autenticación y Gestión de Sesión

7.4. Diagrama de Componentes

Muestra la arquitectura por capas del sistema con la capa de seguridad explícita: Helmet.js (cabeceras HTTP), CORS restringido, Rate Limiter, middleware de autenticación JWT y RBAC. La función `registrarAuditoria()` se muestra como componente transversal que se invoca desde todos los módulos funcionales.

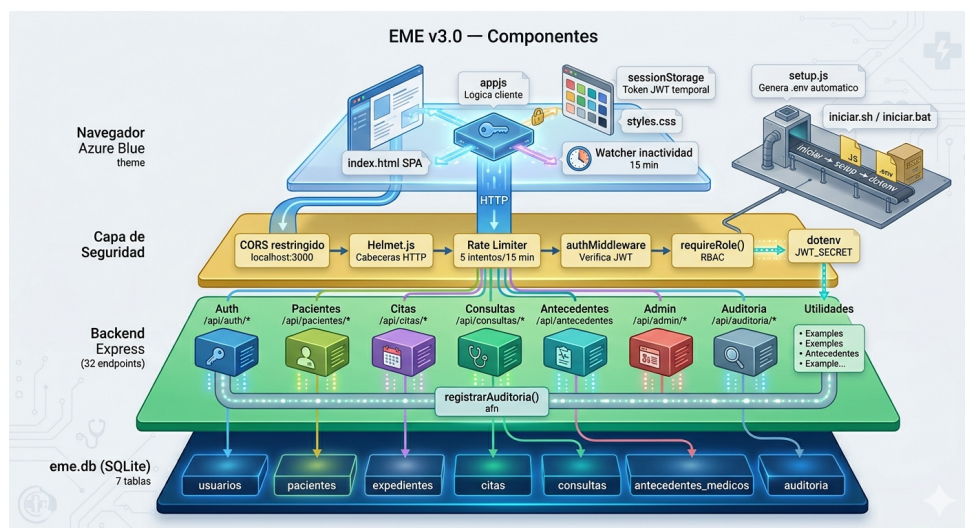


Figure 4: Diagrama de Componentes

7.5. Diagrama de Clases

Modelo orientado a objetos del dominio con las clases: Usuario (con roles admin / medico / recepcionista), Paciente (con campos de eliminación lógica), Expediente, Cita, Consulta, AntecedenteMedico y RegistroAuditoria. La clase Paciente incluye los métodos `eliminar()` (solo médico) y `restaurar()` (solo admin).

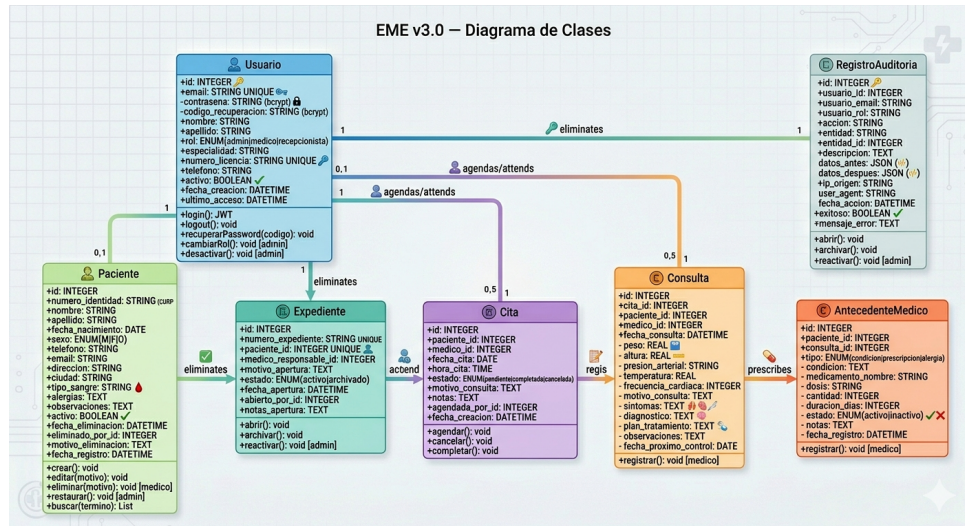


Figure 5: Diagrama de Clases

7.6. Diagrama Entidad-Relación

Esquema de la base de datos con 7 tablas activas: usuarios, pacientes, expedientes, citas, consultas, antecedentes_medicos y auditoria. La tabla pacientes incluye los campos activo, fecha_eliminacion, eliminado_por_id y motivo_eliminacion para la eliminación lógica.

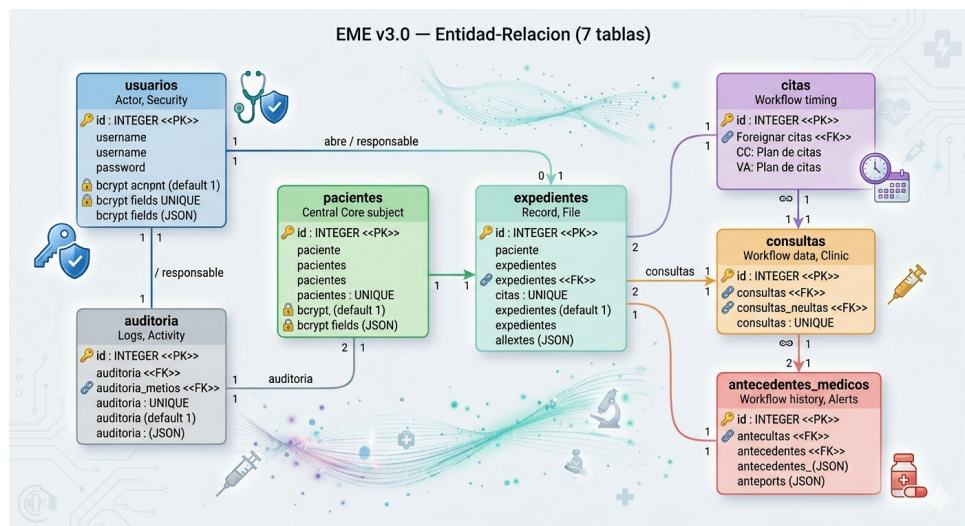


Figure 6: Diagrama Entidad - Relación

7.7. Diagrama de Estados: Cita

Estados posibles de una cita médica (pendiente, completada, cancelada) y las transiciones. Se documenta el comportamiento en cascada: cuando un médico elimina un paciente (soft delete), todas sus citas en estado **pendiente** se cancelan automáticamente.

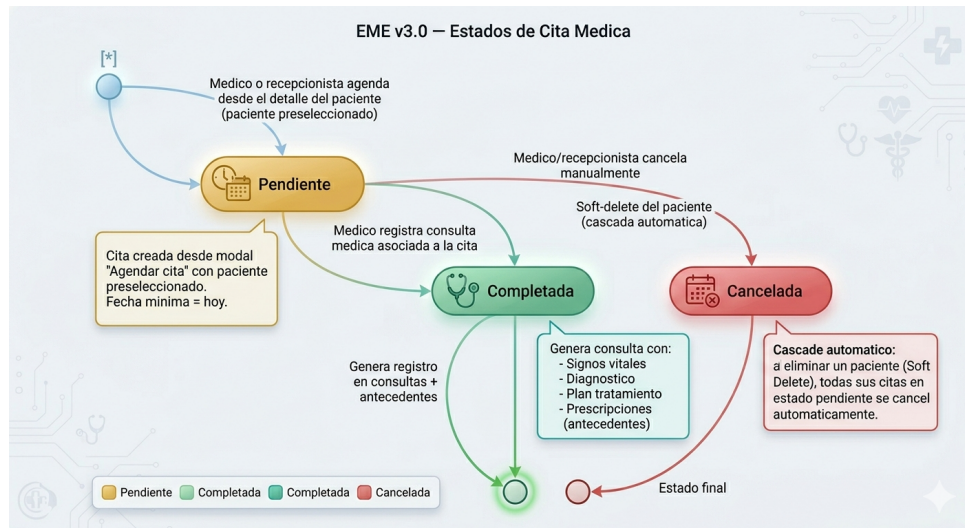


Figure 7: Diagrama de Estados: Cita

7.8. Diagrama de Despliegue

Topología del sistema en la computadora del consultorio. Incluye la capa de seguridad (Helmet, CORS, Rate Limiter), el servidor Node.js con Express, la base de datos SQLite y el navegador con `sessionStorage` y monitor de inactividad. Documenta que el archivo `.env` contiene el `JWT_SECRET` y no se versiona en Git.

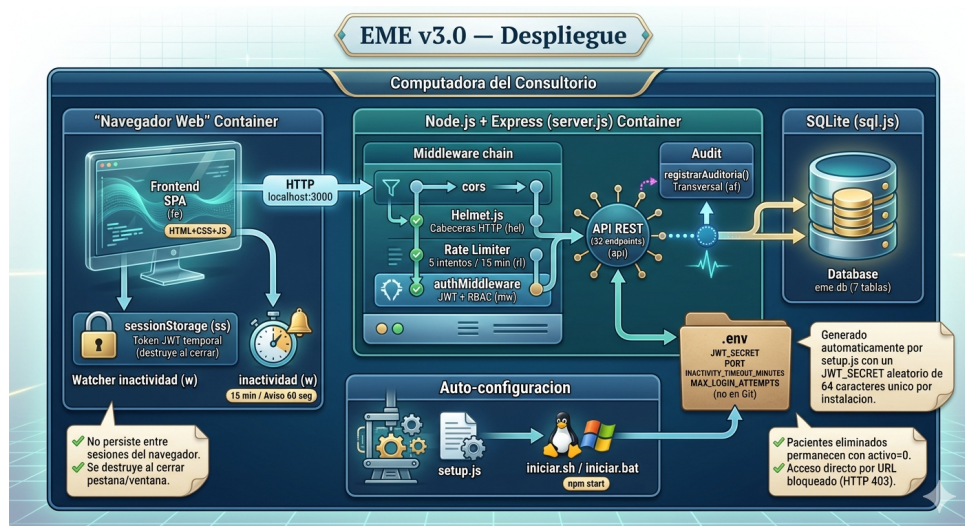


Figure 8: Diagrama de Despliegue

8. Mockups

A continuación se muestran algunas de las interfaces clave que la versión final del sistema implementará. El sistema opera como SPA (Single Page Application) con navegación sin recarga.

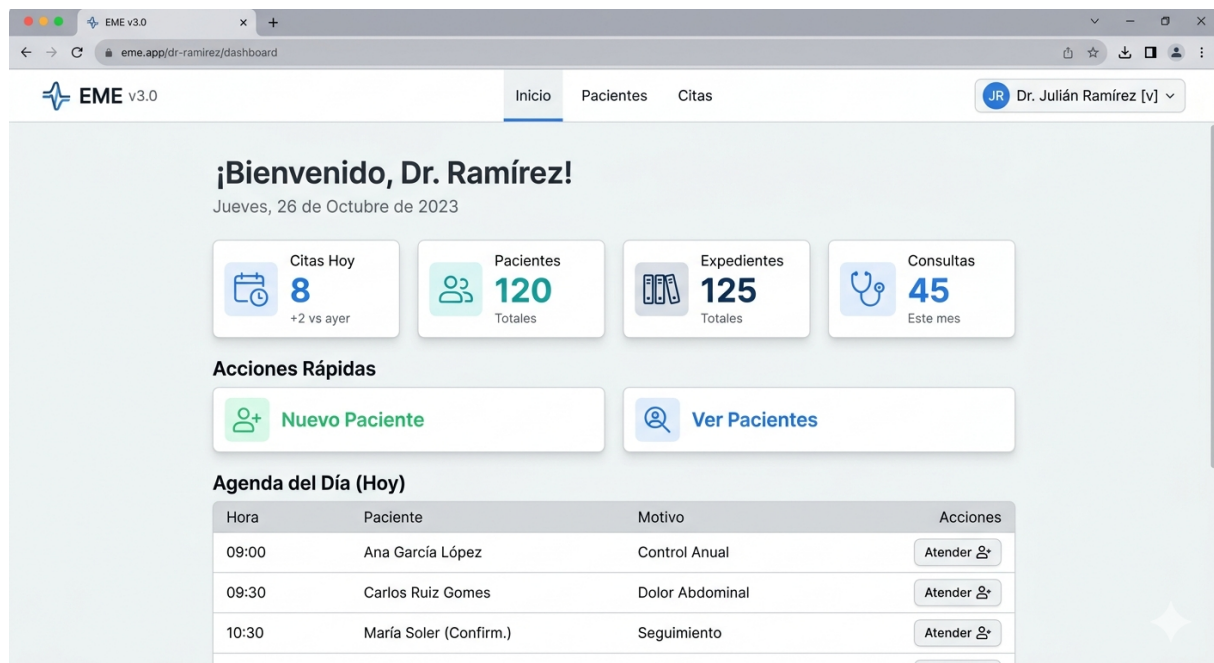


Figure 9: Dashboard del Médico



Figure 10: Hub de Pacientes

The screenshot shows the 'Pacientes' tab in the EME v3.0 application. The patient's name is Ana García López (EXP-2023-0004), registered on 10/01/2023. The page is divided into three main sections: 'Datos Generales', 'Resumen Clínico', and 'Historial de Consultas'.

Datos Generales

- CURP: GALA80...
- Adad: 43 años, 01/01/80)
- Sexo: Femenino
- Tel: 555-1234 Email: ana.garcia@...
- Adrecess: Av. Principal #123, CDMX.

Resumen Clínico

- Tipo Sangre: O+
- Alergias: Penicilina
- Observaciones: Paciente con hipertensión controlada.

Antecedentes

- Hipertensión Arterial (2020)
- Diabetes Tipo II (Diabetes)

Historial de Consultas

Fecha	Médico	Diagnóstico	Acciones
15/10/2023	Dr. Ramírez	Rinitis Alérgica	Ver Detalle
20/05/2023	Dr. Ramírez	Control Hipertensión	Ver Detalle
11/02/2023	Dr. Solana	Control Anual	Ver Detalle

Figure 11: Detalles del paciente

The screenshot shows the 'Agendar Cita Médica' modal in the EME v3.0 application. The modal is open over the patient details page for Ana García López. The modal contains the following information:

Paciente: Ana García López
Expediente: EXP-2023-0004

Fecha: 27/10/2023
Fecha mínima = hoy

Hora: 10:00 AM

Médico Responsable: Dr. Julián Ramírez
Dr. Ramírez (Defecto)

Motivo de Consulta: Seguimiento hipertensión y control general.

Notas Adicionales: Paciente refiere síntomas leves. Revisar medicación.

Buttons: Cancelar, Agendar Cita

Figure 12: Modal Agendar Cita



Figure 13: Dashboard del Administrador

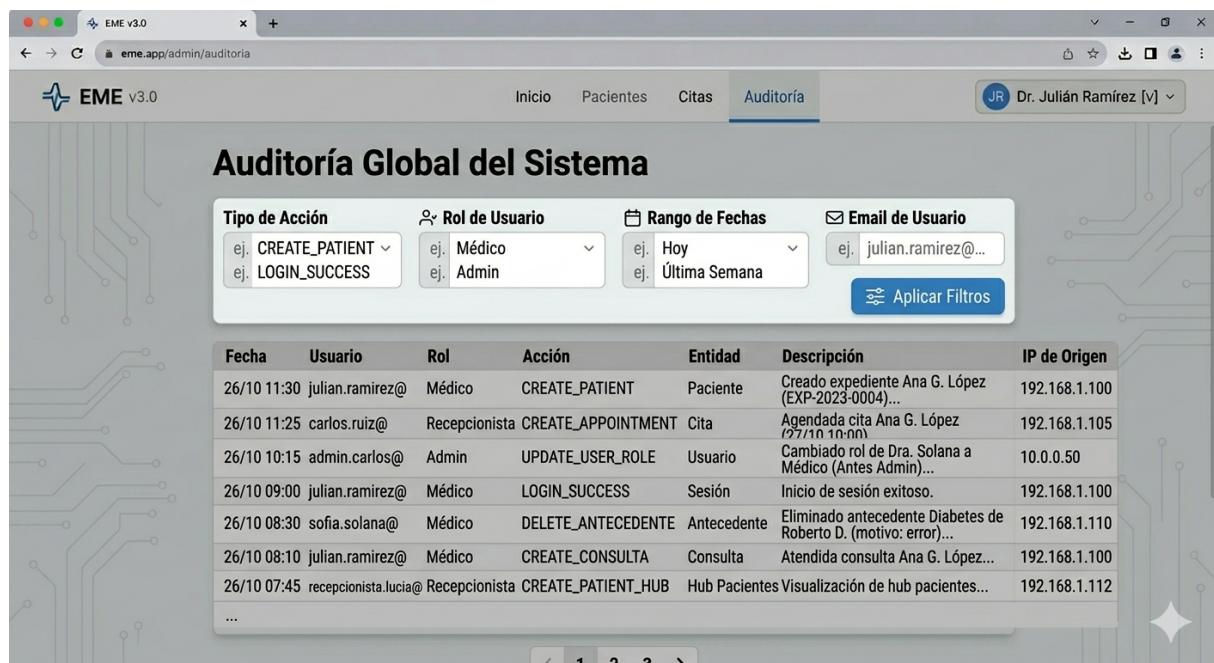


Figure 14: Auditoría del Administrador

9. Conclusiones

El sistema de Expediente Médico Electrónico (EME) se desarrolló como un prototipo funcional completo que cubre el caso de uso de Apertura de Expediente Médico y se extiende para incluir la gestión integral del consultorio, conforme al estándar IEEE 830-1998. El sistema implementa los tres roles diferenciados (Administrador, Médico y Recepcionista), garantiza la confidencialidad de los datos clínicos mediante control de acceso basado en roles (RBAC) y proporciona trazabilidad completa mediante un registro de auditoría inmutable.

La evolución del sistema desde su versión inicial reflejó tres aprendizajes clave. Primero, la incorporación del rol Administrador resolvió la centralización de la gestión de cuentas y la separación de responsabilidades; el mecanismo de *bootstrap* permitió que el primer usuario asumiera este rol sin requerir intervención técnica externa. Segundo, la implementación del hub de pacientes y el agendamiento centrado en el paciente eliminó el problema del dropdown masivo de pacientes y produjo una experiencia más natural alineada al flujo real del consultorio. Tercero, las medidas de hardening de seguridad (Helmet, rate limiting, sessionStorage, timeout de inactividad, .env auto-generado mediante `setup.js`) elevaron la calidad del prototipo a un nivel cercano al de producción.

Como áreas de mejora futura se identifican: la migración a una base de datos cliente-servidor (PostgreSQL o MySQL) para soportar concurrencia real; la incorporación de HTTPS mediante certificados Let's Encrypt; el desarrollo de una aplicación móvil complementaria; la integración con servicios de notificación por correo o SMS; y la implementación de firma digital certificada para las recetas electrónicas. El sistema queda estructurado de forma modular para facilitar estas extensiones sin reescritura mayor del código.

10. Referencias

1. IEEE Computer Society. (1998). *IEEE Std 830-1998: IEEE Recommended Practice for Software Requirements Specifications*. Institute of Electrical and Electronics Engineers.
2. Secretaría de Salud. (2012). *NOM-024-SSA3-2012*. Norma Oficial Mexicana del Expediente Clínico Electrónico.
3. OWASP Foundation. (2023). *OWASP Top 10: 2021*. Recuperado de <https://owasp.org/Top10/>
4. Helmet.js Team. (2024). *Helmet — Help secure Express apps with various HTTP headers*. Recuperado de <https://helmetjs.github.io/>
5. Auth0 Inc. (2024). *JSON Web Tokens — jwt.io*. Recuperado de <https://jwt.io/introduction/>
6. Mozilla Developer Network. (2024). *Web Storage API: sessionStorage*. Recuperado de <https://developer.mozilla.org/en-US/docs/Web/API/Window/sessionStorage>
7. Node.js Foundation. (2024). *Node.js Documentation*. Recuperado de <https://nodejs.org/docs/>
8. Express.js. (2024). *Express — Fast, unopinionated, minimalist web framework for Node.js*. Recuperado de <https://expressjs.com/>

A. Estructura del prototipo

```

eme-prototipo/
|-- server.js Backend Node.js + Express (32 endpoints REST)
|-- setup.js Auto-generador del archivo .env
|-- package.json Dependencias del proyecto
|-- README.md Documentacion de uso
|-- iniciar.sh Script de inicio para Linux/macOS
|-- iniciar.bat Script de inicio para Windows
|-- .env Variables de entorno (auto-generado, no en Git)
|-- .gitignore Excluye .env, node_modules y eme.db
|-- eme.db Base de datos SQLite (auto-generada)
+-- public/
    |-- index.html Frontend SPA con todas las pantallas
    |-- styles.css Estilos visuales del sistema
    +-- app.js Logica del cliente (sessionStorage, modales, timer)

```

Dependencias del proyecto

- **express** — Servidor HTTP
- **bcryptjs** — Hash de contraseñas (10 rondas)
- **jsonwebtoken** — Generación y verificación de JWT
- **sql.js** — SQLite en Node.js sin dependencias nativas
- **dotenv** — Carga de variables de entorno desde **.env**
- **helmet** — Cabeceras de seguridad HTTP automáticas
- **express-rate-limit** — Rate limiting en endpoints de autenticación
- **cors** — Control de orígenes permitidos
- **body-parser** — Parseo de cuerpos JSON

Scripts de inicio

- **iniciar.sh** (Linux/macOS): Verifica Node.js, instala dependencias si no existen y ejecuta **npm start**.
- **iniciar.bat** (Windows): Equivalente para sistemas Windows.
- **setup.js**: Se ejecuta automáticamente antes del servidor (vía **npm start**). Genera el **.env** con un **JWT_SECRET** aleatorio de 64 caracteres si no existe.

B. Tabla de endpoints REST

La siguiente tabla documenta los 32 endpoints de la API REST del sistema EME, con sus métodos HTTP, roles autorizados y descripción funcional.

Método	Endpoint	Roles	Descripción
Autenticación (5)			
GET	/api/auth/setup-status	Público	Estado del sistema (¿requiere bootstrap?)
POST	/api/auth/registro	Bootstrap / Admin	Registrar usuario
POST	/api/auth/login	Público	Iniciar sesión. Rate limit: 5/15 min

Método	Endpoint	Roles	Descripción
POST	/api/auth/verificar-codigo	Público	Verificar código de recuperación
POST	/api/auth/reset-password	Público	Restablecer contraseña
Pacientes (8)			
GET	/api/pacientes	Médico, Recep.	Listar pacientes activos
GET	/api/pacientes/buscar/:termino	Médico, Recep.	Búsqueda inteligente (mín. 3 chars)
GET	/api/pacientes/verificar/:id	Médico, Recep.	Verificar existencia por CURP
GET	/api/pacientes/:id	Médico, Recep.	Detalle (filtrado por rol)
POST	/api/pacientes	Médico, Recep.	Crear paciente sin expediente
POST	/api/pacientes/apertura-expediente	Médico, Recep.	Crear paciente + expediente
PUT	/api/pacientes/:id	Médico, Recep.	Editar (motivo obligatorio)
DELETE	/api/pacientes/:id	Solo médico	Eliminación lógica con cascada
Citas (5)			
GET	/api/citas	Médico, Recep.	Listar citas con filtros
GET	/api/citas/hoy	Médico, Recep.	Citas del día
POST	/api/citas	Médico, Recep.	Agendar cita
PUT	/api/citas/:id	Médico, Recep.	Cambiar estado de cita
DELETE	/api/citas/:id	Médico, Recep.	Cancelar cita
Consultas y Antecedentes (3)			
POST	/api/consultas	Solo médico	Registrar consulta
GET	/api/consultas/:id	Solo médico	Detalle de consulta
POST	/api/antecedentes	Solo médico	Registrar antecedente o prescripción
Auditoría (2)			
GET	/api/auditoria/mias	Todos	Auditoría propia (últimas 100)
GET	/api/auditoria/todas	Solo admin	Auditoría global con filtros
Administración (6, solo Admin)			
GET	/api/admin/usuarios	Solo admin	Listar todos los usuarios
PUT	/api/admin/usuarios/:id	Solo admin	Editar datos de un usuario
PUT	/api/admin/usuarios/:id/estado	Solo admin	Activar/desactivar usuario

Método	Endpoint	Roles	Descripción
GET	/api/admin/pacientes-eliminados	Solo admin	Listar pacientes con activo=0
POST	/api/admin/pacientes/:id/resaltar	Solo admin	Restaurar paciente eliminado
GET	/api/admin/stats	Solo admin	Estadísticas globales
Utilidades (3)			
GET	/api/medicos	Autenticado	Listar médicos activos
GET	/api/dashboard/stats	Autenticado	Estadísticas del dashboard
GET	/api/usuario/info	Autenticado	Datos del usuario en sesión